

Martin Callinan, founder and director of Source Code Control, says, “We work with both sides of the equation-- companies developing software as well as those acquiring software services and solutions.”

Software composition analysis

But how can a developer take care of software licensing and IP while downloading libraries from the Internet? A process called software composition analysis helps here. There are technologies that can scan source code and identify all the copyright, all the licences, third party libraries, version numbers, etc, to see if there are any vulnerabilities in the downloaded libraries. “We build a report called ‘Software Bill of Materials’, which is an itemised list of the makeup of the software,” says Callinan.

So, are developers responsible for intellectual property? Are they solely responsible for security? No, but they do play a role. Source Code Control carries out workshops and helps define rules along with the management -- it creates policies and a training programme for developers. A major constraint in the policy would be that developers cannot bring their code with a licence that may lead to obligations in sharing the code. It also includes the requirement to check for vulnerabilities before using a library from the Internet. Technology can be integrated into the tools that developers use, so that an alert is sent when there is an issue with the software being used. According to Callinan, Software Code Control educates and provides technology to automate software development, avoiding copyright risks.

The business risk is only going to increase. There have been some very big security breaches caused by developers using code off the Internet and companies not tracking it. British Airways faced one of the biggest security breaches in recent times, and had to pay a fine of GBP183

What is OpenChain?

‘Open’ in OpenChain refers to open source, while ‘chain’ refers to the supply chain of software. Developers build and test the software, and then ship it to the customer. This is just like a production line.

The OpenChain initiative tells companies how to manage the quality and delivery of this software supply chain. It trains them on how they need to work to show to the customer that the software they are developing is of high quality. It educates the software company as well as developers on what they should be managing and what they need to avoid.

million. Due to the use of out-of-date components, customer data from the online portal was leaked. The software developer faced a challenge and used 100 lines of code off the Internet, which had not been updated since 2012. Since these lines of code were not tracked, hackers were able to get into the Web portal and collect the data.

India is the open source capital

India, being one of the biggest software development countries in the world, is now also being promoted as the open source capital of the world. The Indian government is leaving no stone unturned in promoting open source for all public software. In such an environment, companies that are unsure of code management are at a risk of not acquiring the required investment, leaving the door open for hackers to exploit code. Source Code Control helps to improve the quality of service from the risk perspective.

Due to Covid-19, movement of infrastructure and applications to the cloud has accelerated. Callinan says, “Source Code Control offers a service called ‘cloud economics’, which provides efficient ways of shifting on-premises infrastructure applications to the public cloud without overspending.”

Making companies investor-ready

From the IP point of view, challenges to share source code picked up from the Internet continue to increase. For example, Tesla is a market leader in

EVs primarily because of the software it has developed. However, the code it used to develop this software was under a licence that obligated the company to share the source code of its navigation system, even if it did not want to. As a result, competing car manufacturers can now have the source code of Tesla’s navigation system and use the best bits for their navigation system.

“Source Code Control works for companies or people investing in tech companies of any size, who first need to understand what’s in the code of the latter. It brings out a report for the investor indicating the obligations to disclose source code, the vulnerabilities in the code, etc. This is called technical due diligence, and no investor will move forward without that,” says Callinan.

The European Union has a security framework standard for the IoT industry that states that its manufacturers must track what components and libraries developers are using that are off the Internet, along with the version numbers, to see how vulnerable they may or may not be. However, there is no such framework for the Indian software market, which is a challenge for the Indian companies developing software for the globe. They face commercial restrictions since they cannot demonstrate the quality of the software development. Source Code Control provides the required services to manage risks and demonstrate the quality of software.